Continuous Dynamic Analysis

Start of Block: Introduction

Title Developer Feedback on Dynamic Analysis Warnings

Intro text: ***Removed for compliance with the double-blind peer review process.***

End of Block: Introduction

Start of Block: Dynamic Analysis Warnings

Descriptive Text Below is a warning identified by the dynamic analysis tools evaluated in the repository **${e://Field/repo_name}**. Please review it carefully before answering the questions that follow. *(This warning was reviewed by one of our collaborators. We are not providing fixes, as we are interested in your independent assessment.)* Warning Details **Warning type:** ${e://Field/violation} **Implication:** ${e://Field/violation_description} | Source → **Triggered by test:** ${e://Field/violation_test} **Code location:** ${e://Field/violation_path} | View on GitHub →

Invest Time How long did you spend inspecting this warning?

	< 1 minutes (1)	1-3 minutes (2)	3-6 minutes (3)	6-10 minutes (4)	10+ minutes (5)
Inspection Time (1)	○	○	○	○	○

To Address? Do you think this warning represents an issue in the codebase that should be fixed?

- ◯ Yes (1)
- ◯ Not necessary, but nice to fix (2)
- ◯ No (3)
- ◯ Unsure (4)

Display this question:

If Do you think this warning represents an issue in the codebase that should be fixed? = Yes

Or Do you think this warning represents an issue in the codebase that should be fixed? = Not necessary, but nice to fix

Fixing What action would you take (or plan to take) to address this warning?

- ◯ Open an issue so others can see and discuss it (1)
- ◯ Commit a fix directly (2)
- ◯ Plan to fix it later (no time to fix it now) (3)
- ◯ Not planning to fix (4)
- ◯ Other (please specify) (5) ____

Display this question:

If Do you think this warning represents an issue in the codebase that should be fixed? = No

Or Do you think this warning represents an issue in the codebase that should be fixed? = Unsure

Not Fixing Why do you think this warning should not be addressed (or why are you unsure)? Please select all that apply.

- ☐ The warning appears to be a false positive (the tool is incorrect). (4)
- ☐ The behavior is intentional in this project. (5)
- ☐ The issue is low priority or low impact. (6)
- ☐ The warning lacks sufficient context or explanation. (7)
- ☐ Fixing this issue would require significant changes to the codebase. (8)
- ☐ The issue originates from an external dependency or library. (9)
- ☐ This part of the code is no longer actively maintained. (10)
- ☐ I would suppress or ignore this warning (e.g., add a suppression comment). (11)
- ☐ Other (please specify) (12) ____

Page Break

Allow Invest Time How long would you typically be willing to spend investigating a warning with the same severity as the warning shown previously?

- ○ < 1 minutes (1)
- ○ 1-3 minutes (2)
- ○ 3-6 minutes (3)
- ○ 6-10 minutes (4)
- ○ 10+ minutes (6)
- ○ Depends on severity (5)

More Information In addition to the information we provided previously, what additional information would help you better understand, investigate, or fix such a warning reported by the dynamic analysis tools we evaluated?

Page Break

Dashboard (current) You can explore the complete dynamic analysis results for the repository **${e://Field/repo_name}** on our dashboard, including all warnings detected in one of the recent commits (one example was shown in the previous section).   View results for the recent commit →

Library Violations As shown above in the dashboard, many warnings come from third-party libraries in addition to your own code. **How do you view these dependency-related warnings?**

- ◯ I would actively investigate and try to fix them (1)
- ◯ I would review them, but only act if they affect my code (4)
- ◯ I would review them occasionally, depending on context (5)
- ◯ I would generally ignore them unless they cause issues (6)
- ◯ I would ignore them, as they are outside my control (7)
- ◯ Other (please specify) (8) ____

Page Break

Dashboard (history) In addition to the warnings detected in the recent commit shown in the previous section, we also ran the dynamic analysis tools we evaluated on historical commits of the repository **${e://Field/repo_name}** to show how warnings evolve over time. Explore warning history →

History Violations The dashboard above shows that some warnings detected by the dynamic analysis tools we evaluated remain unfixed for extended periods of time. **What do you think are the main reasons for this?**

____

____

____

____

____

End of Block: Dynamic Analysis Warnings

Start of Block: Tool Runtime Cost

Descriptive Text Running the two dynamic analysis tools we evaluated on the repository **${e://Field/repo_name}** in our CI environment added approximately **${e://Field/overhead_percentage}x** runtime overhead when monitoring **project code only**, and **${e://Field/overhead_libs_percentage}x** when monitoring **both project code and third-party libraries**, compared to your normal test runs. **Normal test run:** **DyLin (project code only):** **PyMOP (project code only):** **PyMOP (project code + libraries):** function format(val) { return val === "Not available" ? val : val + " seconds"; } document.getElementById("org").innerText = format("${e://Field/overhead_org_time}"); document.getElementById("dylin").innerText = format("${e://Field/overhead_dylin_time}"); document.getElementById("pymop").innerText = format("${e://Field/overhead_pymop_time}"); document.getElementById("pymop_libs").innerText = format("${e://Field/overhead_pymop_libs_time}"); These results were obtained in a standardized CI environment using 8 CPU cores and 32 GB of memory on an AMD-based system, by running all checkers and specifications available in our setup (**15 for DyLin** and **81 for PyMOP**). Actual overhead may vary depending on your CI setup and which checks are enabled.

Acceptable Overhead Based on the results above for **monitoring project code only**, would this runtime overhead be acceptable in your CI workflow?

- ◯ Up to 2× runtime is acceptable (6)
- ◯ Up to 5× runtime is acceptable (13)
- ◯ Up to 10× runtime is acceptable (14)
- ◯ Up to 25× runtime is acceptable (15)
- ◯ Up to 50× runtime is acceptable (18)
- ◯ Any slowdown is acceptable (17)

Library Overhead When would you enable **monitoring of third-party libraries** in addition to project code, considering the additional runtime overhead compared to monitoring project code only?

- ◯ Yes, I would generally enable it, even with noticeable overhead (1)
- ◯ Yes, but only if the overhead is moderate (4)
- ◯ Sometimes, depending on the importance of the repository or feature (5)
- ◯ Sometimes, only when investigating bugs or debugging issues (6)
- ◯ Sometimes, only if the warnings are actionable or high quality (7)
- ◯ No, I would generally not enable it due to the overhead (8)

End of Block: Tool Runtime Cost

Start of Block: Current Tooling

Project Tooling Do you currently use any static analysis tools in the repository **${e://Field/repo_name}**? Please select all that apply.

- ☐ Linters (Flake8, ESLint, Pylint, etc.) (1)
- ☐ Type checkers (mypy, Pyright, etc.) (2)
- ☐ Security scanners (3)
- ☐ AI code review tools (GitHub Copilot, CodeRabbit, etc.) (4)
- ☐ Custom/internal tools (5)
- ☐ None (6)
- ☐ Other (please specify - not listed above or unsure of the exact type) (7) ____

End of Block: Current Tooling

Start of Block: Desired Features

New Features Which factors would matter to you if you were to adopt the dynamic analysis tools we evaluated? Please select all that apply.

- ☐ High accuracy (few false positives) (1)
- ☐ Clear explanation of warnings (2)
- ☐ Suggested fixes (3)
- ☐ Minimal runtime overhead (4)
- ☐ CI integration (5)
- ☐ Security-related findings (6)
- ☐ Performance-related findings (7)
- ☐ Low setup effort (8)
- ☐ Other (please specify) (9) ____

Integrations If you were to adopt the dynamic analysis tools we evaluated, how would you prefer to integrate them into your development workflow?

- ○ Run in a separate CI workflow (e.g., a dedicated GitHub Actions job) (1)
- ○ Integrated into the existing test workflow in CI (2)
- ○ Run locally before pushing commits (3)
- ○ Run locally before opening a pull request (4)
- ○ Run periodically (e.g., nightly CI jobs) (5)
- ○ Other (please specify) (6)

____

End of Block: Desired Features

Start of Block: Open Feedback

Feedback Any additional thoughts or feedback about these warnings or dynamic analysis tools like these?

____

____

____

____

____

JS

Follow-up Discussion Would you be interested in participating in a short follow-up discussion or learning more about the dynamic analysis tool used in this study? If yes, please select the checkbox below.

- ☐ Yes, please contact me for a follow-up discussion or more information. (1)

End of Block: Open Feedback